요구사항 명세서(SRS) 초안

논문-7: ABE + IBS 기반 종단간 보안 프로토콜 → 금융 IoT 적용

Secure End-to-End Vehicular Communication Protocol — Financial IoT Application

1. 문서 정보

문서명	[프로젝트명] 요구사항 명세서(SRS)
버전	v0.1
작성일	2026-04-04
작성자	[이름]
대상	논리 설계 + 시뮬레이션 기반 평가

2. 용어/약어

CAV	Connected and Autonomous Vehicle — 커넥티드 자율주행 차량
ECU	Electronic Control Unit — 차량 내부 전자제어장치 (자원 제한 단말)
OBU	On-Board Unit — 차량 단말기 (에지 노드 역할)
ABE	Attribute-Based Encryption — 속성 기반 암호화
OEEP-ABE	Outsourcing-Enabled and Enhanced Privacy-preserving ABE — 연산 위탁 강화 프라이버시 ABE
IBS	Identity-Based Signature — 아이덴티티 기반 서명
PID	Pseudo-Identity — 가상 식별자 (실신원 은닉)
Policy Privacy	접근 정책 정보를 암호문에 노출하지 않는 정책 은닉 기법
UDM/ARPF	5G 핵심망의 통합 데이터 관리/인증 자격 증명 저장소 (신뢰 기관 역할)
TPM	Trusted Platform Module — ECU 의 하드웨어 보안 모듈
V2X	Vehicle-to-Everything — 차량과 외부(인프라·차량·보행자) 간 통신

E2E	End-to-End — 외부 네트워크부터 차량 내부 ECU 까지의 종단간 보안
FDS	Fraud Detection System — 이상금융거래탐지시스템
Non-colluding SA	공모하지 않는 두 보안 에이전트 — OEEP-ABE 의 위탁 연산 구조

3. 목표 및 성공 기준

3.1 목표

- G1: ABE + IBS 기반 종단간(E2E) 보안 프로토콜(절차/데이터/역할)을 설계한다.
- G2: 자원 제한 ECU 의 연산 부담을 OEEP-ABE 위탁 방식으로 완화하는 아키텍처를 명세한다.
- G3: 가상 식별자(PID) 기반 프라이버시 보호 및 조건부 추적 가능성 설계를 명세한다.
- G4: 금융 IoT·모바일뱅킹 보안에 적용 가능한 연산 위탁형 접근 제어 모델을 제시한다.

3.2 성공 기준

- SC-01: ECU 단독 ABE vs. OEEP-ABE 위탁 방식 비교표(지연·연산량·보안성)를 제시한다.
- SC-02: PID 생성·갱신·조건부 역추적 흐름을 시나리오로 명세한다.
- SC-03: 금융 IoT 단말(저사양) 적용 시나리오를 최소 2 개 제시한다.
- SC-04: 정책 프라이버시(Policy Privacy) 보호 메커니즘을 공격 시나리오로 검증한다.

4. 범위

In-scope

- ABE + IBS 기반 E2E 보안 프로토콜 논리 설계, OEEP-ABE 연산 위탁 흐름
- PID 가상 식별자 정책, 조건부 추적 가능성(UDM/ARPF 역할)
- 금융 IoT 저사양 단말 적용(FDS, 모바일뱅킹 단말), 시뮬레이션 평가

Out-of-scope

- 실제 차량 CAN 버스 구현, 5G 핵심망 실 연동, TPM 하드웨어 구현

5. 시스템 개요(논리 아키텍처)

구성요소

- 자원 제한 단말(ECU / 금융 IoT 단말) — 경량 복호화, PID 생성
- 에지 노드(OBU / 금융 에지 서버) — OEEP-ABE 위탁 연산(Out.Encrypt1)
- 신뢰 기관(TA / UDM·금융보안원) — 키 발급, PID 역추적 권한
- 외부 네트워크(V2X / 금융 클라우드) — 암호화 데이터 전달

데이터 항목 정의(최소)

- D1: PID(가상 식별자), 서명 키, 속성 집합
- D2: 접근 정책(Policy, 암호문 내재 — 은닉)
- D3: 이벤트 로그(접근·인증·이상탐지 이력)

6. 요구사항 우선순위 규칙

등급	레이블	설명
P0	Must	없으면 시스템 성립 불가
P1	Should	성능/완성도에 중요
P2	Could	있으면 좋음(부가)

7. 기능 요구사항(FR)

FR-01: 단말 등록 및 PID 발급	
우선순위	P0
설명	시스템은 자원 제한 단말(ECU/금융 IoT 단말)을 신뢰 기관(TA)에 등록하고, 가상 식별자(PID)와 서명 키를 발급해야 한다.
근거(Rationale)	실 신원 노출 없이 통신하기 위한 프라이버시 보호의 전제.
입력(Input)	단말 ID, 공개키/검증정보, 속성 집합
처리(Process)	TA 가 PID = SUCIn ⊕ H(yCNαn) 형식으로 PID 생성; TPM 기반 서명 키 안전 저장

출력(Output)	발급된 PID, 서명 키, 유효기간
예외/오류	중복 등록, 공개키 위조
검증(Verification)	발급된 PID 로 인증 성공하고, 실 신원은 TA 만 역추적 가능한지

FR-02: OEEP-ABE 연산 위탁 암호화	
우선순위	P0
설명	시스템은 복잡한 ABE 암호화 연산을 에지 노드(OBU/금융 에지 서버)의 두 비공모 SA 에 위탁하여 자원 제한 단말의 부담을 최소화해야 한다.
근거(Rationale)	ECU/금융 IoT 단말의 연산 제약 해소 — 실시간 금융 거래 처리 가능.
입력(Input)	속성 집합, 접근 정책, 공개키
처리(Process)	SA1·SA2(비공모)가 각각 Out.Encrypt1 으로 부분 암호문 생성; 단말은 Out.Encrypt2(경량)만 수행
출력(Output)	완성된 ABE 암호문(정책 은닉 포함)
예외/오류	SA 공모 시도, 위탁 노드 미응답
검증(Verification)	SA1·SA2 각각의 부분 암호문만으로는 복호화 불가하고, 단말에서 최종 결합 시 성공하는지

FR-03: 정책 프라이버시(Policy Privacy) 보호	
우선순위	P0
설명	시스템은 암호화된 메시지에서 접근 정책 정보가 외부(에지 노드 포함)에 노출되지 않아야 한다.
입력(Input)	암호화된 메시지 튜플, 정책 정보
처리(Process)	접근 정책을 암호문 내 은닉; 에지 노드는 정책 내용 파악 불가
출력(Output)	암호문(정책 정보 비노출)
예외/오류	정책 분석 공격 시도
검증(Verification)	에지 노드가 암호문에서 접근 정책(수신자 속성 조건)을 유추하지 못하는지

FR-04: 경량 복호화(단말 측)	
우선순위	P0
설명	시스템은 자원 제한 단말이 속성 개수와 무관하게 일정한 연산량으로 복호화할 수 있어야 한다.
입력(Input)	에지 노드가 제공한 부분 복호화 결과, 단말 개인키
처리(Process)	에지 노드가 ProxyDecrypt1(부분 복호화) 수행 → 단말이 최종 경량 복호화만 실행
출력(Output)	복호화된 메시지, 처리 지연 측정값
예외/오류	부분 복호화 결과 변조
검증(Verification)	속성 수 증가 시에도 단말 복호화 지연이 일정 수준으로 유지되는지

FR-05: PID 주기적 갱신 및 연결불가능성 보장	
우선순위	P0
설명	시스템은 단말이 영역을 이동하거나 토큰이 만료될 때 PID 와 서명 키를 갱신하여 이동 경로 추적을 방지해야 한다.
입력(Input)	갱신 트리거(이동 이벤트 / 만료), 이전 PID
처리(Process)	새 PID 및 서명 키 생성; 이전 PID 와의 연결 불가능성 보장
출력(Output)	갱신된 PID, 연결불가능성 확인
예외/오류	갱신 실패 시 이전 PID 계속 사용 → 보안 취약
검증(Verification)	연속된 두 세션에서 PID 가 달라 외부에서 동일 단말로 연결 불가한지

FR-06: 조건부 추적 가능성(사고 시 역추적)	
우선순위	P1
설명	시스템은 금융 사고·이상거래 발생 시 신뢰 기관(TA)이 PID 를 역추적하여 실제 단말/사용자를 식별할 수 있어야 한다.
입력(Input)	사고 이벤트, 해당 PID, TA 마스터 키
처리(Process)	TA 가 PID → 실 신원 역산; 일반 상황에서는 역추적 불가

출력(Output)	실 신원 식별 결과(TA 권한 범위 내)
예외/오류	TA 없이 역추적 시도 — 실패 처리 필요
검증(Verification)	TA 권한 없는 제 3 자가 PID 로 실 신원을 유추하지 못하는지

FR-07: 금융 IoT 이상거래 탐지(FDS) 연계	
우선순위	P1
설명	시스템은 금융 IoT 단말에서 발생하는 거래 데이터를 E2E 암호화 상태로 FDS 서버에 전달하고, 이상 패턴 탐지 결과를 안전하게 반환해야 한다.
입력(Input)	암호화된 거래 데이터(ABE), 단말 PID
처리(Process)	FDS 서버가 암호화 상태에서 정책 일치 여부 확인; 이상 패턴 탐지 후 결과 반환
출력(Output)	이상거래 탐지 결과, 조치 명령
예외/오류	FDS 서버의 정책 미매칭, 단말 미인증
검증(Verification)	FDS 서버가 암호문 내용을 복호화하지 않고도 이상 패턴을 탐지할 수 있는지

8. 비기능 요구사항(NFR)

NFR-01: 성능 — 연산 위탁 효과 검증	
우선순위	P0
설명	OEEP-ABE 위탁 방식에서 단말의 암호화/복호화 지연이 단독 ABE 방식 대비 유의미하게 감소함을 시뮬레이션으로 검증해야 한다.
검증(Verification)	속성 수별 단말 처리 지연 비교표가 정의되어 있는지

NFR-02: 보안 — 정책 프라이버시·PID 보호	
우선순위	P0
설명	에지 노드 및 외부 공격자가 암호문에서 접근 정책과 단말 PID 를 유추하지 못해야 한다.
검증(Verification)	공격 시나리오(정책 분석/PID 연결)에서 방어 단계가 명확히 정의되어 있는지

NFR-03: 확장성 — 단말 수 증가	
우선순위	P0
설명	금융 IoT 환경에서 단말 수 증가 시 에지 노드 위탁 연산의 병목 지점을 식별하고 완화 설계를 제시해야 한다.
검증(Verification)	단말 수 증가 시나리오(최소 2 개)에서 병목과 완화 방안이 정의되어 있는지

NFR-04: 감사 가능성 — 조건부 추적	
우선순위	P1
설명	사고 발생 시 TA 만이 PID 를 역추적하여 실 신원을 확인할 수 있고, 그 이력이 감사 로그로 기록되어야 한다.
검증(Verification)	감사 시나리오('언제/어떤 PID/어떤 결과') 재구성이 가능한지

9. 가정/제약

- A1: 두 SA(보안 에이전트)는 서로 공모하지 않는 환경을 가정한다.
- A2: 신뢰 기관(TA)은 완전히 신뢰된 제 3 자 환경을 가정한다.
- A3: 실제 차량 CAN 버스 연동 없이 논리 흐름·지연 모델 기반 시뮬레이션으로 평가한다.
- A4: 금융 IoT 적용 시나리오는 자원 제한 단말(처리 능력 낮음)을 가정한다.

10. 검증/테스트/평가 계획

- EV-01: 단독 ABE vs. OEEP-ABE 위탁 방식 단말 처리 지연 비교
- EV-02: PID 갱신 시나리오 — 연속 세션 연결불가능성 검증
- EV-03: 정책 프라이버시 공격 시나리오 (에지 노드의 정책 유추 시도 차단)
- EV-04: 조건부 역추적 시나리오 (TA 권한 내 PID → 실 신원 확인, 제 3 자 차단)
- EV-05: FDS 연계 시나리오 — 암호화 상태 이상거래 탐지 정확도
- EV-06: 단말 수 증가 확장성 시나리오 (에지 노드 위탁 부하 분석)

부록 A. 자료조사 요약(요구사항 근거)

요구사항	근거 (자료조사 요약)
FR-02 근거	OEEP-ABE 의 연산 위탁 구조가 자원 제한 ECU·금융 IoT 단말의 실시간 처리를 가능하게 함
FR-05/06 근거	PID 기반 익명성 + 조건부 역추적은 금융 이상거래 조사·책임추적 요건을 동시에 충족
NFR-02 근거	정책 은닉(Policy Privacy)으로 공격자가 암호문에서 거래 조건·수신자 속성을 유추하는 것을 원천 차단